MK Consults Gap Analysis Workbook (completed)

Your Audit Ally | Gap analysis template for ISO/IEC 27001:2022

Purpose	Assess how far current practice is from ISO/IEC 27001:2022. Use it for the initial gap analysis (before the business case: a quick pass through every clause requirement and Annex A control, mainly by interview) and for the detailed gap assessment (after the ISMS scope is approved: full evidence for each row).
Sheets	Clauses 4-10: mandatory management system requirements. Annex A Controls: baseline of the 93 controls already in place. Summary: totals by clause and by Annex A section (A.5 to A.8).
What to fill in	Only the yellow cells: REQUIREMENT MET (choose from the drop-down) and COMMENTS / GAP IDENTIFIED. Everything else is reference content.
Requirement met	Yes: documented, operating, and evidence seen. Partially: done but not documented, documented but not done, or inconsistent. No: not in place. Not applicable: Annex A only, and only with a reason in comments.
How to assess	Interview the people who own each area, ask open questions, then ask to see the evidence listed. Record what you saw, not what you were told. If there is no evidence, it is not Yes.
Annex A rule	This sheet records current state only. It does not decide which controls apply. Control selection comes from risk treatment (Clause 6.1.3) and is recorded in the Statement of Applicability.
Example (Clause 5.2)	Requirement met: Partially. Comments: An acceptable use document exists (2023) but there is no approved information security policy, no objectives framework, and no evidence it was communicated to staff.
Copyright note	Requirements are paraphrased for guidance and are not the text of the standard. Always refer to your licensed copy of ISO/IEC 27001:2022 (including Amd 1:2024) for the authoritative wording.

MK Consults Gap Analysis Summary

Initial gap analysis completed by the CISO, ISMS champion (Levi Hartley), 17 to 28 August 2026, against the working scope. Source for ISMS-GAP-001 Readiness Summary. Counts update automatically from the Clauses 4-10 and Annex A Controls sheets.

AREA	REQUIREMENTS	YES	PARTIALLY	NO	NOT APPLICABLE	NOT YET ASSESSED	% MET (YES)
Clauses 4 to 10							
Clause 4: Context of the organization	4	0	2	2	0	0	0%
Clause 5: Leadership	3	0	1	2	0	0	0%
Clause 6: Planning	5	0	0	5	0	0	0%
Clause 7: Support	7	0	4	3	0	0	0%
Clause 8: Operation	3	0	1	2	0	0	0%
Clause 9: Performance evaluation	6	0	0	6	0	0	0%
Clause 10: Improvement	2	0	1	1	0	0	0%
Total	**30**	**0**	**9**	**21**	**0**	**0**	**0%**
Annex A Controls							
A.5 Organizational controls (37)	37	4	12	21	0	0	11%
A.6 People controls (8)	8	2	4	2	0	0	25%
A.7 Physical controls (14)	14	6	3	5	0	0	43%
A.8 Technological controls (34)	34	9	15	10	0	0	26%
Total	**93**	**21**	**34**	**38**	**0**	**0**	**23%**

% met excludes "Not applicable". Clauses 4 to 10 cannot be marked not applicable.

MK Consults Gap Analysis: Clauses 4 to 10

Initial gap analysis completed by the CISO, ISMS champion (Levi Hartley), 17 to 28 August 2026, against the working scope. Source for ISMS-GAP-001 Readiness Summary. Mandatory requirements. Every row applies: clauses cannot be excluded. "(mandatory)" marks documented information the standard requires.

CLAUSE	REF	TITLE	REQUIREMENT (PARAPHRASED)	DOCUMENTS NEEDED	EVIDENCE TO CONFIRM COMPLIANCE	REQUIREMENT MET	COMMENTS / GAP IDENTIFIED
Clause 4: Context of the organization							
4	4.1	**Understanding the organization and its context**	Identify the internal and external issues relevant to the organization's purpose that affect its ability to achieve the ISMS's intended outcomes. Consider climate change where relevant (Amd 1:2024).	Context analysis (e.g. PESTLE/SWOT or issues register). Not mandatory as a document, but expected.	Issues register or workshop output; evidence it was reviewed; issues reflected in scope and risk assessment.	**Partially**	Issues are understood informally (client demands, remote working, AWS reliance) but have never been documented or reviewed.
4	4.2	**Understanding the needs and expectations of interested parties**	Determine the interested parties relevant to the ISMS, their relevant requirements, and which of those requirements will be addressed through the ISMS.	Interested parties register with requirements and how each is addressed.	Register listing parties, requirements (legal, regulatory, contractual) and whether each is addressed through the ISMS (4.2 c).	**Partially**	Client and regulatory requirements are known from contracts and questionnaires; no register, and no decision on which requirements the ISMS addresses.
4	4.3	**Determining the scope of the ISMS**	Define the boundaries and applicability of the ISMS, considering 4.1, 4.2 and the interfaces and dependencies between activities performed by the organization and by others.	ISMS Scope Statement (mandatory).	Approved, version-controlled scope statement covering organisational, technology, physical and information boundaries, interfaces, dependencies and justified exclusions.	**No**	No scope defined. Working scope assumed for this analysis.
4	4.4	**Information security management system**	Establish, implement, maintain and continually improve an ISMS, including the processes needed and their interactions.	ISMS manual or process overview (optional).	Evidence the ISMS processes exist and interact: documented processes, records of operation, improvement history.	**No**	No management system in place.
Clause 5: Leadership							
5	5.1	**Leadership and commitment**	Top management demonstrates leadership: policy and objectives aligned with strategy, ISMS integrated into processes, resources available, importance communicated, outcomes achieved, people directed and supported, continual improvement promoted, other managers supported.	Management commitment statement (optional); evidence of resource approval.	Signed commitment, approved budget, management review minutes, top management able to explain the ISMS at interview.	**Partially**	CEO supportive and sponsoring this analysis; no formal commitment, resources or accountability yet.
5	5.2	**Policy**	Top management establishes an information security policy appropriate to the organization's purpose, including objectives or a framework for them, a commitment to meet applicable requirements and to continual improvement. It must be communicated and available to interested parties as appropriate.	Information Security Policy (mandatory).	Approved, dated policy; evidence it was communicated to staff (acknowledgements, intranet) and is available to interested parties.	**No**	No approved policy. Informal acceptable-use expectations only.
5	5.3	**Organizational roles, responsibilities and authorities**	Top management assigns and communicates responsibilities and authorities for roles relevant to information security, including for ISMS conformance and reporting on ISMS performance.	Roles and responsibilities document or RACI; appointment letters.	Named role holders, communicated assignments, job descriptions or RACI, evidence of reporting to top management.	**No**	Security responsibilities sit informally with the CISO and Head of IT; not defined or communicated.
Clause 6: Planning							
6	6.1.1	**Actions to address risks and opportunities: general**	When planning the ISMS, consider issues (4.1) and requirements (4.2), and determine risks and opportunities to address so the ISMS achieves its outcomes, prevents undesired effects and achieves continual improvement. Plan actions and how to evaluate their effectiveness.	Covered by risk management methodology and plans.	Evidence that ISMS-level risks and opportunities were identified and actions planned.	**No**	Not addressed.
6	6.1.2	**Information security risk assessment**	Define and apply a risk assessment process that sets risk acceptance criteria and criteria for performing assessments, produces consistent and comparable results, identifies risks to confidentiality, integrity and availability with risk owners, analyses likelihood and consequences, and evaluates and prioritises risks.	Risk assessment process / methodology (mandatory).	Approved methodology with acceptance criteria; risk register showing risk owners, likelihood, consequence and risk levels.	**No**	No method, no acceptance criteria, no risk register.
6	6.1.3	**Information security risk treatment**	Define and apply a risk treatment process: select treatment options, determine necessary controls, compare them with Annex A to verify none are omitted, produce a Statement of Applicability, formulate a risk treatment plan, and obtain risk owners' approval of the plan and acceptance of residual risk.	Risk treatment process (mandatory); Statement of Applicability (mandatory); risk treatment plan.	SoA with justification and implementation status for each Annex A control; risk treatment plan; signed risk owner approval and residual risk acceptance.	**No**	No treatment process, no Statement of Applicability.
6	6.2	**Information security objectives and planning to achieve them**	Set measurable information security objectives at relevant functions and levels, consistent with the policy. Plan what will be done, resources, who is responsible, completion dates and how results will be evaluated.	Information security objectives (mandatory).	Objectives document with measures, owners, resources, dates and evaluation method; evidence of tracking.	**No**	No measurable objectives.
6	6.3	**Planning of changes**	When changes to the ISMS are needed, carry them out in a planned manner.	Change records for ISMS changes (no specific document required).	Records showing ISMS changes were planned, assessed and approved.	**No**	No planned change process for security.
Clause 7: Support							
7	7.1	**Resources**	Determine and provide the resources needed to establish, implement, maintain and continually improve the ISMS.	Budget and resource plan (optional).	Approved budget, allocated people and time, tooling in place.	**Partially**	Skilled people and tooling exist; no resources allocated to an ISMS.
7	7.2	**Competence**	Determine the competence needed for people affecting information security performance, ensure they are competent through education, training or experience, take action to acquire competence where needed, and evaluate effectiveness.	Evidence of competence (mandatory).	Competence requirements per role; training records, certifications, CVs; evaluation of training effectiveness.	**Partially**	Security and IT staff experienced and certified; competence requirements and records not defined.
7	7.3	**Awareness**	People working under the organization's control are aware of the policy, their contribution to the ISMS and the implications of not conforming.	Awareness programme or plan (optional).	Training attendance records, completion rates, staff able to explain the policy and their role at interview.	**No**	No awareness programme; last company-wide session could not be evidenced.

7	7.4	**Communication**	Determine the need for internal and external communications: what, when, with whom and how.	Communication plan or matrix (optional).	Communication plan; examples of internal announcements and external communications.	**Partially**	Ad hoc security messages via Slack; no communication plan.
7	7.5.1	**Documented information: general**	The ISMS includes the documented information required by the standard and that the organization determines is necessary for its effectiveness.	Documented information determined as necessary (mandatory).	Document register or library listing ISMS documents.	**No**	No defined set of ISMS documents.
7	7.5.2	**Creating and updating**	When creating and updating documented information, ensure appropriate identification, format and media, and review and approval for suitability.	Document control procedure (optional).	Documents carry ID, version, owner, approval; review history.	**No**	No document identification, versioning or approval convention.
7	7.5.3	**Control of documented information**	Control documented information so it is available and protected: distribution, access, storage, preservation, change control, retention and disposition, including external documents.	Document control procedure (optional); retention schedule.	Access-controlled repository, version history, retention rules applied, external documents identified and controlled.	**Partially**	Confluence and SharePoint used with access controls; no retention or change control rules.
Clause 8: Operation							
8	8.1	**Operational planning and control**	Plan, implement and control the processes needed to meet requirements and implement the actions from Clause 6, establish criteria for those processes, control planned changes, and control externally provided processes, products or services.	Documented information to the extent necessary to have confidence processes were carried out as planned (mandatory).	Operating records, procedures in use, change records, supplier controls for outsourced processes.	**Partially**	Technical operations run well day to day; no defined security processes or control of outsourced services beyond standard contracts.
8	8.2	**Information security risk assessment**	Perform risk assessments at planned intervals and when significant changes occur, using the criteria from 6.1.2.	Results of risk assessments (mandatory).	Dated risk assessment results; evidence of reassessment at planned intervals and after significant change.	**No**	Never performed.
8	8.3	**Information security risk treatment**	Implement the risk treatment plan.	Results of risk treatment (mandatory).	Risk treatment plan progress; implemented controls traced to treated risks.	**No**	Never performed.
Clause 9: Performance evaluation							
9	9.1	**Monitoring, measurement, analysis and evaluation**	Determine what is monitored and measured, methods, when, who, and when results are analysed and evaluated. Evaluate information security performance and ISMS effectiveness.	Evidence of monitoring and measurement results (mandatory).	Metrics definitions, dashboards or reports, analysis and evaluation records.	**No**	No security metrics or reporting.
9	9.2.1	**Internal audit: general**	Conduct internal audits at planned intervals to check the ISMS conforms to the organization's own requirements and the standard, and is effectively implemented and maintained.	Internal audit reports.	Completed internal audits covering the full ISMS scope within the cycle.	**No**	Never performed.
9	9.2.2	**Internal audit programme**	Plan, establish, implement and maintain an audit programme with frequency, methods, responsibilities and reporting. Define criteria and scope for each audit, select objective and impartial auditors, and report results to relevant management.	Evidence of audit programme and audit results (mandatory).	Audit programme, audit plans, auditor independence, audit reports, reporting to management.	**No**	None.
9	9.3.1	**Management review: general**	Top management reviews the ISMS at planned intervals to ensure its continuing suitability, adequacy and effectiveness.	Management review schedule.	Management reviews held at planned intervals, attended by top management.	**No**	Never held.
9	9.3.2	**Management review inputs**	Review covers status of previous actions, changes in issues and interested parties' needs, feedback on performance (nonconformities, monitoring results, audit results, objectives), interested party feedback, risk assessment results and treatment plan status, and opportunities for improvement.	Management review agenda and input pack.	Agenda and pack covering all required inputs.	**No**	No review inputs defined.
9	9.3.3	**Management review results**	Results include decisions on continual improvement opportunities and any need for changes to the ISMS.	Evidence of management review results (mandatory).	Signed minutes with decisions and actions, owners and dates.	**No**	None.
Clause 10: Improvement							
10	10.1	**Continual improvement**	Continually improve the suitability, adequacy and effectiveness of the ISMS.	Improvement log (optional).	Improvement actions raised and implemented; trend of improvements over time.	**Partially**	Improvements happen after incidents, informally.
10	10.2	**Nonconformity and corrective action**	React to nonconformities: control and correct them, deal with consequences, evaluate the need to remove root causes, implement actions, review effectiveness, and make ISMS changes where needed.	Nature of nonconformities, actions taken and results of corrective actions (mandatory).	Nonconformity and corrective action log with root cause analysis and effectiveness review.	**No**	Incidents fixed as they arise; no log and no root cause analysis.

MK Consults Gap Analysis: Annex A Controls

Initial gap analysis completed by the CISO, ISMS champion (Levi Hartley), 17 to 28 August 2026, against the working scope. Source for ISMS-GAP-001 Readiness Summary. Baseline of controls already in place. This records current state only: which controls apply is decided by risk treatment and recorded in the Statement of Applicability. Documents listed are typical, not mandatory.

SECTION	REF	TITLE	REQUIREMENT (PARAPHRASED)	DOCUMENTS NEEDED	EVIDENCE TO CONFIRM COMPLIANCE	REQUIREMENT MET	COMMENTS / GAP IDENTIFIED
A.5 Organizational controls (37)							
A.5 Organizational	5.1	**Policies for information security**	Define an information security policy and topic-specific policies, approved by management, published, communicated, acknowledged and reviewed at planned intervals.	Information Security Policy; topic-specific policies.	Approved policies, review dates, staff acknowledgements.	No	No information security policy or topic-specific policies.
A.5 Organizational	5.2	**Information security roles and responsibilities**	Define and allocate information security roles and responsibilities according to the organization's needs.	Roles and responsibilities / RACI.	Named role holders, job descriptions, RACI.	Partially	Security duties held informally by the CISO and Head of IT; not defined.
A.5 Organizational	5.3	**Segregation of duties**	Segregate conflicting duties and areas of responsibility.	Segregation of duties matrix.	Role conflicts identified; access and approval workflows enforce separation.	Partially	Some separation in finance approvals; not assessed for security.
A.5 Organizational	5.4	**Management responsibilities**	Management requires all personnel to apply information security in line with policies and procedures.	Policy acknowledgement process; employment terms.	Management communications; signed acknowledgements.	No	No management requirement to follow security policies.
A.5 Organizational	5.5	**Contact with authorities**	Establish and maintain contact with relevant authorities.	Contact list of authorities (regulators, data protection authority, law enforcement).	Current contact list; incident procedure referencing authorities.	No	No contact list for authorities.
A.5 Organizational	5.6	**Contact with special interest groups**	Maintain contact with special interest groups, security forums and professional associations.	List of memberships or subscriptions.	Memberships, forum participation, advisory subscriptions.	Yes	Active memberships in security and GRC professional bodies.
A.5 Organizational	5.7	**Threat intelligence**	Collect and analyse information about threats to produce threat intelligence.	Threat intelligence process.	Threat feeds or sources, analysis records, actions taken.	No	No threat intelligence process.
A.5 Organizational	5.8	**Information security in project management**	Integrate information security into project management.	Project methodology with security steps.	Security requirements and risk checks in project records.	No	Security not part of internal or client project methodology.
A.5 Organizational	5.9	**Inventory of information and other associated assets**	Develop and maintain an inventory of information and associated assets, including owners.	Asset inventory.	Current inventory with owners and classification; review records.	No	No asset inventory.
A.5 Organizational	5.10	**Acceptable use of information and other associated assets**	Identify, document and implement rules for acceptable use and handling of information and assets.	Acceptable Use Policy.	Approved policy; staff acknowledgements.	Partially	Acceptable use expectations exist informally; no approved policy.
A.5 Organizational	5.11	**Return of assets**	Personnel and other parties return organizational assets when employment, contract or agreement ends.	Offboarding procedure / checklist.	Completed offboarding checklists showing assets returned.	No	No offboarding checklist covering return of assets.
A.5 Organizational	5.12	**Classification of information**	Classify information according to security needs based on confidentiality, integrity, availability and interested party requirements.	Information classification policy / scheme.	Classification scheme; sample of classified information.	No	No classification scheme.
A.5 Organizational	5.13	**Labelling of information**	Develop and implement procedures for labelling information in line with the classification scheme.	Labelling procedure.	Labelled documents, email or system labels in use.	No	No labelling.
A.5 Organizational	5.14	**Information transfer**	Put rules, procedures or agreements in place for all types of information transfer, internally and with other parties.	Information transfer policy; transfer agreements.	Approved transfer methods, encryption in transit, client transfer agreements.	Partially	Encrypted transfer used for clients; no rules or agreements.
A.5 Organizational	5.15	**Access control**	Establish and implement rules for physical and logical access control based on business and security requirements.	Access Control Policy.	Approved policy; access model applied in key systems.	Partially	Access granted by role in practice; no access control policy.
A.5 Organizational	5.16	**Identity management**	Manage the full life cycle of identities.	Identity management procedure.	Joiner, mover and leaver records; unique IDs; removal of orphaned accounts.	Partially	Unique accounts via Microsoft 365; no joiner, mover, leaver process.
A.5 Organizational	5.17	**Authentication information**	Control the allocation and management of authentication information, including advising personnel on handling it.	Password / authentication policy.	Password manager, secure credential issuance, MFA configuration.	Yes	Company password manager in use; credentials issued securely.
A.5 Organizational	5.18	**Access rights**	Provision, review, modify and remove access rights according to the access control policy.	Access request and review procedure.	Access requests with approvals; periodic access review records; timely removal.	Partially	Access requested by ticket; no periodic access reviews.
A.5 Organizational	5.19	**Information security in supplier relationships**	Define and implement processes to manage information security risks from the use of suppliers' products or services.	Supplier security policy / procedure.	Supplier inventory with risk ratings; due diligence records.	No	No supplier security risk process.
A.5 Organizational	5.20	**Addressing information security within supplier agreements**	Establish and agree relevant information security requirements with each supplier.	Contract security clauses; data processing agreements.	Signed agreements containing security requirements.	Partially	Standard provider terms and DPAs in place; security clauses not reviewed.
A.5 Organizational	5.21	**Managing information security in the ICT supply chain**	Define and implement processes to manage risks associated with the ICT products and services supply chain.	ICT supply chain procedure.	Assessment of key ICT vendors and their sub-suppliers.	No	ICT supply chain not assessed.
A.5 Organizational	5.22	**Monitoring, review and change management of supplier services**	Regularly monitor, review, evaluate and manage change in supplier security practices and service delivery.	Supplier review procedure.	Supplier review records, SOC 2 / ISO certificate reviews, change notices.	No	No supplier service reviews.
A.5 Organizational	5.23	**Information security for use of cloud services**	Establish processes for acquiring, using, managing and exiting cloud services in line with security requirements.	Cloud security policy; shared responsibility matrix.	Cloud service inventory, shared responsibility mapping, exit considerations.	Partially	AWS and Microsoft 365 used securely; shared responsibility not documented.
A.5 Organizational	5.24	**Information security incident management planning and preparation**	Plan and prepare for incident management by defining processes, roles and responsibilities.	Incident management procedure / plan.	Approved plan, defined roles, contact lists, tabletop exercise records.	No	No incident management plan.
A.5 Organizational	5.25	**Assessment and decision on information security events**	Assess security events and decide whether to categorize them as incidents.	Event triage criteria.	Event log with triage decisions.	No	No event triage criteria.
A.5 Organizational	5.26	**Response to information security incidents**	Respond to incidents in accordance with documented procedures.	Incident response procedure / playbooks.	Incident records showing response steps followed.	Partially	Incidents handled ad hoc by IT; no procedure.
A.5 Organizational	5.27	**Learning from information security incidents**	Use knowledge gained from incidents to strengthen and improve controls.	Post-incident review template.	Lessons learned records and resulting improvements.	No	No post-incident reviews.
A.5 Organizational	5.28	**Collection of evidence**	Establish procedures for identifying, collecting, acquiring and preserving evidence related to security events.	Evidence handling procedure.	Chain of custody records where applicable.	No	No evidence handling procedure.
A.5 Organizational	5.29	**Information security during disruption**	Plan how to maintain information security at an appropriate level during disruption.	Business continuity plan with security considerations.	BCP including security requirements; test records.	No	No continuity plan covering security.
A.5 Organizational	5.30	**ICT readiness for business continuity**	Plan, implement, maintain and test ICT readiness based on continuity objectives and requirements.	ICT continuity / disaster recovery plan.	Defined RTO and RPO; DR test results.	No	No ICT continuity or recovery objectives.
A.5 Organizational	5.31	**Legal, statutory, regulatory and contractual requirements**	Identify, document and keep up to date the legal, statutory, regulatory and contractual requirements relevant to information security and the approach to meet them.	Legal and regulatory requirements register.	Current register; owner; review records.	Partially	Requirements understood via external legal advisor; no register.
A.5 Organizational	5.32	**Intellectual property rights**	Implement procedures to protect intellectual property rights.	IP and software licensing procedure.	Licence records, software inventory, IP clauses.	Yes	Software licensed through managed SaaS subscriptions; IP clauses in contracts.
A.5 Organizational	5.33	**Protection of records**	Protect records from loss, destruction, falsification, unauthorized access and unauthorized release.	Records retention schedule.	Retention schedule applied; access-controlled record storage.	Partially	Records stored in Microsoft 365 with access control; no retention schedule.
A.5 Organizational	5.34	**Privacy and protection of PII**	Identify and meet requirements for preserving privacy and protecting personally identifiable information according to applicable laws, regulations and contracts.	Privacy policy; record of processing activities; DPIAs.	GDPR records, privacy notices, DPIAs, data subject request log.	Yes	GDPR records of processing, privacy notices and DPIAs maintained with legal advisor.
A.5 Organizational	5.35	**Independent review of information security**	Review the organization's approach to information security independently at planned intervals or when significant changes occur.	Independent review plan.	Internal audit or external review reports.	No	No independent review of security.
A.5 Organizational	5.36	**Compliance with policies, rules and standards for information security**	Regularly review compliance with the information security policy, topic-specific policies, rules and standards.	Compliance review procedure.	Compliance check records, management reviews of compliance.	No	No compliance checks.

A.5 Organizational	5.37	**Documented operating procedures**	Document operating procedures for information processing facilities and make them available to personnel who need them.	Operating procedures (e.g. backup, user admin, patching).	Procedures available to relevant staff and in use.	**No**	Operating procedures not documented.
A.6 People controls (8)							
A.6 People	6.1	**Screening**	Carry out background verification checks on candidates before joining and on an ongoing basis, proportionate to business requirements, regulations and risk.	Screening procedure.	Screening records for a sample of recent hires.	**Partially**	References checked for new hires; no screening procedure.
A.6 People	6.2	**Terms and conditions of employment**	Employment contracts state personnel's and the organization's information security responsibilities.	Employment contract template with security clauses.	Signed contracts containing security responsibilities.	**Yes**	Employment contracts include confidentiality and security obligations.
A.6 People	6.3	**Information security awareness, education and training**	Personnel receive appropriate awareness, education and training and regular updates relevant to their job function.	Awareness and training programme.	Training records, completion rates, phishing simulation results.	**No**	No awareness or training programme.
A.6 People	6.4	**Disciplinary process**	Formalize and communicate a disciplinary process for personnel who violate the information security policy.	Disciplinary procedure referencing security.	Communicated procedure; records where applied.	**Partially**	HR disciplinary process exists; does not reference security.
A.6 People	6.5	**Responsibilities after termination or change of employment**	Define, enforce and communicate security responsibilities that remain valid after termination or change of employment.	Leaver procedure; post-employment clauses.	Exit communications; contract clauses.	**Partially**	Contract clauses survive termination; not communicated at exit.
A.6 People	6.6	**Confidentiality or non-disclosure agreements**	Identify, document, regularly review and sign confidentiality or non-disclosure agreements reflecting the organization's needs.	NDA templates.	Signed NDAs for staff, contractors and relevant third parties.	**Yes**	NDAs signed by staff, contractors and key third parties.
A.6 People	6.7	**Remote working**	Implement security measures for personnel working remotely to protect information accessed, processed or stored outside the organization's premises.	Remote working policy.	Approved policy; technical controls such as MDM, VPN or zero trust access.	**Partially**	Remote working practices in place; no policy.
A.6 People	6.8	**Information security event reporting**	Provide a mechanism for personnel to report observed or suspected security events promptly through appropriate channels.	Event reporting procedure.	Reporting channel in place; reports received; staff aware of how to report.	**No**	No defined channel for reporting security events.
A.7 Physical controls (14)							
A.7 Physical	7.1	**Physical security perimeters**	Define and use security perimeters to protect areas containing information and associated assets.	Physical security policy; site plan.	Defined perimeters for offices or data rooms in scope.	**Yes**	Data centre perimeters provided by AWS; office in managed building.
A.7 Physical	7.2	**Physical entry**	Protect secure areas with appropriate entry controls and access points.	Physical access procedure.	Access control system, visitor logs, key or badge records.	**Yes**	Badge entry to office building; AWS data centre entry controls.
A.7 Physical	7.3	**Securing offices, rooms and facilities**	Design and implement physical security for offices, rooms and facilities.	Physical security standard.	Locked rooms, secure storage, observation.	**Partially**	Office locked; no physical security standard.
A.7 Physical	7.4	**Physical security monitoring**	Continuously monitor premises for unauthorized physical access.	Monitoring arrangements.	CCTV, alarms or building security services where applicable.	**Yes**	Building security monitoring; AWS data centre monitoring.
A.7 Physical	7.5	**Protecting against physical and environmental threats**	Design and implement protection against physical and environmental threats such as natural disasters and other intentional or unintentional threats.	Environmental risk assessment.	Fire suppression, environmental controls, provider attestations for hosted facilities.	**Yes**	Environmental protection provided by AWS and building management.
A.7 Physical	7.6	**Working in secure areas**	Design and implement security measures for working in secure areas.	Secure area rules.	Rules communicated; observation.	**No**	No secure area rules.
A.7 Physical	7.7	**Clear desk and clear screen**	Define and enforce clear desk rules for papers and removable media and clear screen rules for information processing facilities.	Clear desk and clear screen policy.	Screen lock settings enforced; spot checks.	**Partially**	Screen lock enforced through MDM; no clear desk rule.
A.7 Physical	7.8	**Equipment siting and protection**	Site equipment securely and protect it.	Equipment siting guidance.	Observation of equipment placement and protection.	**No**	No guidance for siting equipment at home.
A.7 Physical	7.9	**Security of assets off-premises**	Protect assets used off-site.	Remote working / mobile device policy.	Encrypted laptops, MDM, travel guidance.	**Partially**	Laptops encrypted; no rules for using equipment off-premises.
A.7 Physical	7.10	**Storage media**	Manage storage media through acquisition, use, transport and disposal in line with classification and handling requirements.	Media handling procedure.	Removable media controls, encryption, disposal records.	**No**	No removable media controls.
A.7 Physical	7.11	**Supporting utilities**	Protect information processing facilities from power failures and other disruptions caused by failures in supporting utilities.	Utility resilience arrangements.	UPS, provider resilience attestations for cloud and hosting.	**Yes**	Supporting utilities resilience provided by AWS.
A.7 Physical	7.12	**Cabling security**	Protect cables carrying power, data or supporting services from interception, interference or damage.	Cabling standard.	Observation; provider attestations.	**Yes**	Cabling security provided by AWS and building management.
A.7 Physical	7.13	**Equipment maintenance**	Maintain equipment correctly to ensure availability, integrity and confidentiality of information.	Maintenance schedule.	Maintenance records; vendor support contracts.	**No**	No maintenance records for equipment.
A.7 Physical	7.14	**Secure disposal or re-use of equipment**	Verify equipment containing storage media to ensure sensitive data and licensed software are removed or securely overwritten before disposal or re-use.	Secure disposal procedure.	Wipe or destruction certificates; asset disposal log.	**No**	No secure disposal or wipe records.
A.8 Technological controls (34)							
A.8 Technological	8.1	**User endpoint devices**	Protect information stored on, processed by or accessible via user endpoint devices.	Endpoint security policy.	MDM enrolment, disk encryption, endpoint protection status reports.	**Yes**	Laptops MDM-enrolled, encrypted and protected.
A.8 Technological	8.2	**Privileged access rights**	Restrict and manage the allocation and use of privileged access rights.	Privileged access procedure.	List of privileged accounts, approvals, periodic reviews, separate admin accounts.	**Partially**	Admin accounts limited; not reviewed; some shared admin use.
A.8 Technological	8.3	**Information access restriction**	Restrict access to information and associated assets according to the access control policy.	Access Control Policy.	Role-based permissions in systems; sample checks.	**Partially**	Permissions set per system; not aligned to a policy.
A.8 Technological	8.4	**Access to source code**	Appropriately manage read and write access to source code, development tools and software libraries.	Source code access procedure.	Repository permissions, branch protection, access reviews.	**Yes**	GitHub permissions and branch protection in place.
A.8 Technological	8.5	**Secure authentication**	Implement secure authentication technologies and procedures based on access restrictions and the access control policy.	Authentication standard.	MFA enforcement reports, SSO configuration, login controls.	**Partially**	MFA on most core systems; exceptions found; not enforced everywhere.
A.8 Technological	8.6	**Capacity management**	Monitor and adjust the use of resources in line with current and expected capacity requirements.	Capacity management procedure.	Capacity monitoring dashboards, alerts, scaling configuration.	**Yes**	AWS monitoring and autoscaling in place.
A.8 Technological	8.7	**Protection against malware**	Implement protection against malware, supported by appropriate user awareness.	Malware protection standard.	Endpoint protection coverage and update status; awareness content.	**Yes**	Endpoint protection deployed and up to date.
A.8 Technological	8.8	**Management of technical vulnerabilities**	Obtain information about technical vulnerabilities, evaluate exposure and take appropriate measures.	Vulnerability and patch management procedure.	Scan results, patching records against SLAs, penetration test reports.	**Partially**	Patching done; no vulnerability scanning or SLAs.
A.8 Technological	8.9	**Configuration management**	Establish, document, implement, monitor and review configurations, including security configurations, of hardware, software, services and networks.	Configuration standards / baselines.	Hardened baselines, infrastructure as code, configuration drift checks.	**Partially**	Infrastructure partly defined as code; no documented baselines.
A.8 Technological	8.10	**Information deletion**	Delete information stored in systems, devices or other media when no longer required.	Data retention and deletion procedure.	Deletion records, automated retention rules.	**No**	No deletion rules.
A.8 Technological	8.11	**Data masking**	Use data masking in line with the access control policy, other topic-specific policies and business requirements, considering applicable legislation.	Data masking standard.	Masked or pseudonymised data in non-production and reports.	**No**	No data masking.
A.8 Technological	8.12	**Data leakage prevention**	Apply data leakage prevention measures to systems, networks and devices that process, store or transmit sensitive information.	DLP standard.	DLP policies configured, alerts and handling records.	**No**	No data leakage prevention.
A.8 Technological	8.13	**Information backup**	Maintain backup copies of information, software and systems and test them regularly in line with the backup policy.	Backup policy.	Backup job reports, restore test records.	**Partially**	Backups run automatically; restores never tested.
A.8 Technological	8.14	**Redundancy of information processing facilities**	Implement information processing facilities with redundancy sufficient to meet availability requirements.	Availability / resilience design.	Multi-zone or failover architecture, availability reports.	**Yes**	Multi-zone AWS architecture.
A.8 Technological	8.15	**Logging**	Produce, store, protect and analyse logs that record activities, exceptions, faults and other relevant events.	Logging standard.	Centralised logs, retention settings, log protection.	**Partially**	Logs collected in AWS and Microsoft 365; not reviewed.
A.8 Technological	8.16	**Monitoring activities**	Monitor networks, systems and applications for anomalous behaviour and take appropriate action on potential incidents.	Security monitoring procedure.	Alerting rules, SIEM or monitoring dashboards, alert handling records.	**No**	No security monitoring or alerting.

A.8 Technological	8.17	**Clock synchronization**	Synchronize the clocks of information processing systems to approved time sources.	Time synchronization standard.	NTP configuration evidence.	**Yes**	Clocks synchronised through AWS and Microsoft 365.
A.8 Technological	8.18	**Use of privileged utility programs**	Restrict and tightly control utility programs capable of overriding system and application controls.	Privileged utilities procedure.	Restricted access to admin tools; usage logs.	**No**	No control of privileged utility programs.
A.8 Technological	8.19	**Installation of software on operational systems**	Implement procedures and measures to manage software installation on operational systems.	Software installation procedure.	Restricted install rights, approved software list, change records.	**Partially**	MDM limits installation on laptops; no procedure for servers.
A.8 Technological	8.20	**Networks security**	Secure, manage and control networks and network devices to protect information in systems and applications.	Network security standard.	Firewall and security group rules, network diagrams, reviews.	**Partially**	AWS security groups in place; no network diagram or reviews.
A.8 Technological	8.21	**Security of network services**	Identify, implement and monitor security mechanisms, service levels and requirements of network services.	Network service requirements.	Provider agreements, configuration of network services.	**Yes**	Network services provided under AWS and Microsoft agreements.
A.8 Technological	8.22	**Segregation of networks**	Segregate groups of information services, users and systems in networks.	Network segregation design.	VPC or VLAN segregation, environment separation evidence.	**Yes**	Environments separated in distinct AWS accounts and VPCs.
A.8 Technological	8.23	**Web filtering**	Manage access to external websites to reduce exposure to malicious content.	Web filtering standard.	DNS or web filtering configuration and reports.	**No**	No web filtering.
A.8 Technological	8.24	**Use of cryptography**	Define and implement rules for effective use of cryptography, including key management.	Cryptography policy; key management procedure.	Encryption at rest and in transit settings, key management records.	**Partially**	Encryption at rest and in transit enabled; no cryptography policy.
A.8 Technological	8.25	**Secure development life cycle**	Establish and apply rules for the secure development of software and systems.	Secure development policy.	SDLC documentation, security steps in pipelines.	**Partially**	Development practices exist; no secure development policy.
A.8 Technological	8.26	**Application security requirements**	Identify, specify and approve information security requirements when developing or acquiring applications.	Application security requirements template.	Security requirements in tickets or specifications.	**Partially**	Some security requirements in tickets; not systematic.
A.8 Technological	8.27	**Secure system architecture and engineering principles**	Establish, document, maintain and apply principles for engineering secure systems in development activities.	Secure architecture principles.	Architecture reviews, design records applying the principles.	**No**	No secure architecture principles.
A.8 Technological	8.28	**Secure coding**	Apply secure coding principles to software development.	Secure coding standard.	Code review records, static analysis results, developer training.	**Partially**	Code reviewed through pull requests; no secure coding standard.
A.8 Technological	8.29	**Security testing in development and acceptance**	Define and implement security testing processes in the development life cycle.	Security testing procedure.	Test results, SAST and DAST reports, acceptance sign-off.	**Partially**	Some automated code scanning; no security testing procedure.
A.8 Technological	8.30	**Outsourced development**	Direct, monitor and review activities related to outsourced system development.	Outsourced development requirements.	Contracts with security terms, reviews of delivered code.	**No**	Outsourced development not controlled; use to be confirmed.
A.8 Technological	8.31	**Separation of development, test and production environments**	Separate and secure development, testing and production environments.	Environment separation standard.	Separate accounts or environments, restricted production access.	**Yes**	Development, test and production in separate AWS accounts.
A.8 Technological	8.32	**Change management**	Subject changes to information processing facilities and systems to change management procedures.	Change management procedure.	Change tickets with approval, testing and rollback evidence.	**Partially**	Changes approved through pull requests; no change procedure for infrastructure.
A.8 Technological	8.33	**Test information**	Appropriately select, protect and manage test information.	Test data procedure.	No live personal data in test, or approved and masked where used.	**No**	No rules for test data.
A.8 Technological	8.34	**Protection of information systems during audit testing**	Plan and agree audit tests and other assurance activities involving operational systems between the tester and management.	Audit testing rules of engagement.	Agreed scopes and approvals for audits and penetration tests.	**No**	No rules of engagement for audit testing.